

OWASP Cheat-Sheet for Agentic Agencies

One-page reference. Print double-sided. Hand to every attendee.

OWASP is the vendor-neutral framework professional security teams anchor to. When you tell an enterprise client "we're OWASP-aligned," you're speaking their language. This sheet condenses the two Top 10s that matter for agencies running agentic systems.

OWASP Top 10 for LLM Applications (the new one)

The framework that *didn't exist* three years ago. Now the most relevant security doc in the room.

CODE	NAME	WHAT IT LOOKS LIKE AT YOUR AGENCY
LLM01	Prompt Injection	Untrusted text in a tool result (web page, fetched email, user comment) hijacks your agent's instructions. Defense: separate retrieval from action; treat tool output as untrusted.
LLM02	Insecure Output Handling	Your agent's output is rendered as HTML/SQL/shell without sanitization. Defense: escape on the way out, not just on the way in.
LLM03	Training Data Poisoning	Less direct concern for you (you're using foundation models, not training). Stay aware.
LLM04	Model Denial of Service	Adversarial prompts that burn your token budget. Defense: rate limits, cost ceilings, prompt length caps.
LLM05	Supply Chain Vulnerabilities	npm/pip/MCP supply chain. Shai-Hulud and friends. Defense: lock versions, audit transitively, treat MCP installs as hires.
LLM06	Sensitive Information Disclosure	Your agent leaks secrets, PII, or internal data into its output. Defense: data minimization; never feed secrets into prompt context.
LLM07	Insecure Plugin Design	MCP servers are plugins. Each one runs with the scope you grant it. Defense: vet origin, grant minimum scope, audit on updates.
LLM08	Excessive Agency	Agent has more tool access than the task needs. Defense: principle of least privilege; ask-mode default; bypass only in sandboxes.
LLM09	Overreliance	Your team trusts agent output without verification. Defense: spot-check 3 outputs per session; review before sending.
LLM10	Model Theft	Less direct concern. Relevant if you're fine-tuning.

The five that hit you hardest: LLM01, LLM05, LLM07, LLM08, LLM06.

OWASP Top 10 for Web Applications (the classic)

The foundational list. Every website your agency builds for a client should defend against these.

CODE	NAME	ONE-LINE DEFENSE
A01	Broken Access Control	Every endpoint checks authorization. No "security through obscurity."
A02	Cryptographic Failures	HTTPS everywhere. No homegrown crypto. Hash passwords (bcrypt/argon2).
A03	Injection (SQL, NoSQL, OS, LDAP)	Parameterized queries. Never concatenate user input into commands.
A04	Insecure Design	Threat-model before you build, not after.
A05	Security Misconfiguration	Default creds removed. Verbose errors off in prod. CSP headers set.
A06	Vulnerable & Outdated Components	The CVE backlog. <code>/security-radar</code> catches these.
A07	Identification & Auth Failures	Rate-limit logins. MFA on admin paths. No password leaks.
A08	Software & Data Integrity Failures	Verify package signatures. Sign your CI/CD artifacts.
A09	Security Logging & Monitoring Failures	Log auth events. Alert on patterns. Keep a trail.
A10	Server-Side Request Forgery (SSRF)	Validate URLs your server fetches. Block internal IPs.

The three that hit agency-built sites hardest: A01, A06, A05.

How `/security-radar` maps to these

Every finding the radar tool surfaces is labeled with one of these codes. You're not memorizing the framework — you're building a habit:

"Critical finding · LLM05 Supply Chain · Package X. Fix: bump to version 1.4.2."

That's the language. Once you can name the OWASP code for a finding, you can talk about it with any security team, any enterprise client, any auditor.

When a client asks "are you OWASP-compliant?"

The honest, accurate answer:

"OWASP isn't a compliance regime — it's a threat model. We use the OWASP LLM Top 10 to scope risk in our agentic systems, and the OWASP Web Top 10 for any site we deliver. We monitor our surface continuously with tooling anchored to those frameworks. We can share posture briefs on request."

That answer wins the meeting. Vague answers lose it.

Further reading (one-tap)

- OWASP Top 10 for LLM Applications: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
 - OWASP Top 10 for Web Applications: <https://owasp.org/www-project-top-ten/>
 - OWASP ASVS (deeper standard for the ambitious): <https://owasp.org/www-project-application-security-verification-standard/>
 - OSV.dev (the vuln database the radar tool queries): <https://osv.dev/>
-